

Cybersecurity Daily Newsletter

Vol. 003 | 2026-07-29 09:00 WIB

Top 5 Highlights

- Proof-of-concept exploit released for Certighost Windows AD CS vulnerability
- Arista patches critical command injection flaw in VeloCloud Orchestrator exploited in attacks
- Operation Cronos dismantled LockBit ransomware group by undermining affiliate trust
- Hackers exploit Fastjson vulnerability for remote code execution
- Italian organizations targeted by 148 ransomware attacks in first half of 2026

Threat Intelligence (10)

01. Disrupting supply chain attacks on npm and GitHub Actions

Explore the changes we've shipped across npm and GitHub Actions over the past few months to disrupt supply chain attack techniques and limit their impact. The post Disrupting supply chain attacks on npm and GitHub Actions appeared first on The GitHub Blog .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: <https://github.blog/security/supply-chain-security/disrupting-supply-chain-attacks-on-npm-and-github-actions/>

02. Is Your SSO Protected Against Modern Credential Attacks?

A compromised SSO login can provide attackers with access to multiple enterprise applications and services. Specops Software explains how stronger passwords, phishing-resistant MFA, and identity hardening help secure modern SSO environments and the applications they protect. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.bleepingcomputer.com/news/security/is-your-sso-protected-against-modern-credential-attacks/>

03. Cyberhaven launches Flow to secure data across human and AI workflows

Cyberhaven has introduced Cyberhaven Flow, an AI-native data security platform built to protect data across human and AI workflows. Flow connects lineage, identity, and behavior to protect data as it is created, copied, fragmented, and shared, marking a shift in how protection adapts to the changing context of work in the AI era. Flow secures data across ev...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.helpnetsecurity.com/2026/07/28/cyberhaven-flow/>

04. Infoblox joins crowded EASM market with DNS-centric approach

With AI compressing reconnaissance and exploit development from weeks to hours, security vendors are racing to help enterprises identify exposures long before an incident happens. Infoblox is the latest to make that move, announcing its entry into the External Attack Surface Management (EASM) market alongside a new Supply Chain Intelligence capability tha...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: <https://www.csoononline.com/article/4202205/infoblox-joins-crowded-easm-market-with-dns-centric-approach.html>

05. Phishing Dominates as Initial Entry Method for Cyber-Attacks, as Hackers Hone Evasion Techniques

Analysis of real-life incident response cases by Cisco Talos warns that phishing remains a powerful method of initial compromise

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.infosecurity-magazine.com/news/phishing-dominates-initial-entry/>

06. Nimbus Manticore Deploys NightLedge and Turns Victim Systems Into Covert Relays

The Iranian state-backed hacking group tracked as Nimbus Manticore (aka GalaxyGato, Mirage Kitten, Smoke Sandstorm, Subtle Snail, and UNC1549) has been attributed to a fresh set of attacks targeting entities across the Middle East, Africa, and South Asia. The intrusions involve the use of a previously undocumented Windows backdoor called NightLedge and two...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/07/nimbus-manticore-deploys-nightledge.html>

07. Software Supply Chain Attacks: Weaponizing Trusted Developer Workflows

While operational supply chain compromise remains a risk, attackers are increasingly targeting the development pipelines that build and ship software.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources:

<https://www.intel471.com/blog/software-supply-chain-attacks-weaponizing-trusted-developer-workflows>

08. [+24h Old] Building Resilience Against AiTM Phishing: What SOC Leaders Should Know

Email gateways, endpoint controls, and file-centric sandboxing remain essential layers of defense. But many of today's phishing attacks unfold in ways they weren't designed to

fully expose. How do you build resilience against modern phishing if it has outgrown your SOC's investigation workflows? Rethinking Phishing Investigations in Modern SOCs While initia...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://any.run/cybersecurity-blog/enterprise-phishing-resilience/>

09. [+24h Old] Mirage Kitten targets Middle East and Africa region with new malware

Kaspersky researchers reveal previously undocumented malware attributed to Mirage Kitten (UNC1549, Smoke Sandstorm, Nimbus Manticore): NightLedger backdoor, ArcBridge, and BridgeHead tunneling tools.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://securelist.com/mirage-kitten-new-tools/120811/>

10. [+24h Old] AutoIT Payload Injector , (Tue, Jul 28th)

For a long time, AutoIT[1] has been pretty common in the malware ecosystem. Threat actors still use it because it's easy to write and powerful. Indeed, it can perform all the required actions to inject a payload into a remote process as you'll see below.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://isc.sans.edu/diary/rss/33192>

Latest Vulnerabilities (10)

01. Proof-of-concept exploit released for Certighost Windows AD CS vulnerability

Reported by Bleeping Computer. A proof-of-concept exploit was released for a vulnerability in Windows Active Directory Certificate Services (AD CS) known as Certighost, potentially allowing authenticated attackers to compromise an entire Windows domain.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/brief/proof-of-concept-exploit-released-for-certighost-windows-ad-cs-vulnerability>

02. Arista patches critical command injection flaw in VeloCloud Orchestrator exploited in attacks

As reported by Bleeping Computer, Arista released a patch for a critical command injection vulnerability affecting on-premises VeloCloud Orchestrator (VCO) deployments.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/brief/arista-patches-critical-command-injection-flaw-in-velocloud-orchestrator-exploited-in-attacks>

03. Operation Cronos dismantled LockBit ransomware group by undermining affiliate trust

As reported by Dark Reading, Operation Cronos, a significant international law enforcement effort, successfully dismantled LockBit, once one of the most dominant ransomware-as-a-service (RaaS) operations globally.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/brief/operation-cronos-dismantled-lockbit-ransomware-group-by-undermining-affiliate-trust>

04. Hackers exploit FastJson vulnerability for remote code execution

Bleeping Computer disclosed that hackers are actively exploiting a critical vulnerability in the FastJson open-source Java library, enabling remote code execution without requiring user interaction or elevated privileges.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/brief/hackers-exploit-fastjson-vulnerability-for-remote-code-execution>

05. Ghost Credentials Expose Cloud Systems to Hidden Identity Risks

Security researcher Aleksandr Krasnov reveals dormant non-human identities can create security blind spots and releases NHI Hound, an open source tool to sniff out trust paths.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.darkreading.com/cloud-security/non-human-identity-sprawl-creates-a-new-cloud-attack-path>

06. Malicious Steam workshop map delivered malware to MECCHA CHAMELEON players

As outlined in Cyber Insider, a malicious Steam Workshop map for the game MECCHA CHAMELEON exploited a vulnerability in the game's mod-loading system to deliver malware to players' computers.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/brief/malicious-steam-workshop-map-delivered-malware-to-meccha-chameleon-players>

07. CubePilot drone software dev hit by DNS hijacking to intercept traffic

CubePilot, an Australian firm that designs flight controllers for drones (UAVs), announced a severe operational disruption caused by a DNS hijacking attack. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/cubepilot-drone-software-dev-hit-by-dns-hijacking-to-intercept-traffic/>

08. OpenAI models used Artifactory zero-days to escape to the internet

IFrog has confirmed that OpenAI models exploited zero-day vulnerabilities in self-hosted Artifactory servers to help escape an isolated testing environment and gain access to the internet before attacking Hugging Face. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/openai-models-used-artifactory-zero-days-to-escape-to-the-internet/>

09. Claude AI Just Cracked a Post-Quantum Test Scheme and Found a Faster 7-Round AES Attack

Anthropic says Claude Mythos Preview helped derive an end-to-end key-recovery attack against HAWK-256 and a 200- to 800-fold speedup for an attack on seven-round AES-128. The HAWK attack exploits a previously unused symmetry in the lattice behind the signature scheme. Anthropic's released implementation gives an expected end-to-end runtime of about three ho...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/07/claude-ai-just-cracked-post-quantum.html>

10. VU#141367: AT&T's Arris BGW210-700 gateway contains authentication bypass vulnerability in LAN-side management interface

Overview Firmware versions 2.7.7 and earlier of the Arris BGW210-700 residential gateway contain an authentication bypass vulnerability, tracked as CVE-2026-16771, that allows any unauthenticated LAN-side user to read sensitive configuration data and modify device settings through web management endpoints. Although this vulnerability was recently discovered...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://kb.cert.org/vuls/id/141367>

Data Breach & Cybercrime (10)

01. Italian organizations targeted by 148 ransomware attacks in first half of 2026

Italian organizations faced 148 confirmed ransomware attacks in the first half of 2026, with the manufacturing sector being the most frequently targeted.

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.scworld.com/brief/italian-organizations-targeted-by-148-ransomware-attacks-in-first-half-of-2026>

02. Google introduces new cybercrime naming taxonomy, diverging from Microsoft's initiative

The Register reports that Google unveiled its own taxonomy for categorizing cybercrime groups, a move that appears to sideline a previous industry-wide effort led by Microsoft to standardize threat actor names.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.scworld.com/brief/google-introduces-new-cybercrime-naming-taxonomy-diverging-from-microsofts-initiative>

03. Hugging Face breach reignites open-weights debate, raises liability questions

The first publicly documented cyberattack run end-to-end by an autonomous AI was an OpenAI benchmark test that escaped its sandbox and breached Hugging Face. In an incident post-mortem compiled with the input from Hugging Face and several hundred members of Cloud Security Alliance's CISO community, the nonprofit organization laid out the most salient points...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.helpnetsecurity.com/2026/07/28/hugging-face-breach-ciso-playbook-open-weight-llms/>

04. We rebuilt Malwarebytes Mobile Security for the scams of today

Your phone needs more than a lock screen to stay safe. We've rebuilt Malwarebytes Mobile Security to put scam protection first and keep your phone secure.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.malwarebytes.com/blog/product/2026/07/we-rebuilt-malwarebytes-mobile-security-for-the-scams-of-today>

05. Coca-Cola Reveals Subsidiary Fairlife Suffered Data Breach

Coca Cola claims data was stolen from its Fairlife business after a recent ransomware attack

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.infosecurity-magazine.com/news/coca-cola-subsidiary-fairlife-data/>

06. [+24h Old] Data breach at medical billing firm MCBS affects 1.26 million people

Healthcare billing company Medical Computer Business Services (MCBS) has disclosed that a 2025 network breach exposed the sensitive information of more than 1.2 million people. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/data-breach-at-medical-billing-firm-mcbs-affects-126-million-people/>

07. [+24h Old] Hackers are compromising hotel Wi-Fi gateways to hijack Microsoft 365 accounts

Traveling enterprise employees beware: Think twice before you log onto that oh-so-convenient public Wi-Fi. Since at least June, threat actors have been compromising “captive” Wi-Fi gateways and other portal appliances at hotels, conference centers, and similar shared venues to hijack users’ Microsoft 365 accounts, according to the ReliaQuest Threat Research...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.csoonline.com/article/4202067/hackers-are-compromising-hotel-wi-fi-gateways-to-hijack-microsoft-365-accounts.html>

08. [+24h Old] Samsung’s AI-powered glasses could be looking at your data

Now that Samsung has jumped into the crowded AI-powered glasses arena alongside Apple, Google, Meta, and others, CISOs and IT leaders are having to think through whether it makes sense to establish enterprise restrictions on such devices, given the likely data leakage and compliance issues. And even if those tech leaders decide that such policies might m...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.csoonline.com/article/4201977/samsungs-ai-powered-glasses-could-be-looking-at-your-data.html>

09. [+24h Old] Aftercall ads are driving Android users crazy

A newly uncovered ad fraud campaign is spreading Android apps that display full-screen ads every time you end a phone call.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.malwarebytes.com/blog/news/2026/07/aftercall-ads-are-driving-android-users-crazy>

10. [+24h Old] Apple sued over fake App Store crypto wallet app stealing \$1.8M in Bitcoin

Apple is being sued by three people who claim approximately \$1.8 million in Bitcoin was stolen after downloading and using a fraudulent Sparrow Wallet application from the App Store. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/apple/apple-sued-over-fake-app-store-crypto-wallet-app-stealing-18m-in-bitcoin/>